أسئلة وأجوبة لجنة التحكيم — عربي

أسئلة وأجوبة

إجابات مُعدّة مسبقًا عن أكثر الأسئلة المتوقعة من لجنة التحكيم، وكل إجابة مبنية على الشيفرة والاختبارات والتقارير الهندسية الفعلية لمرقاب.

الفريق

Bdoor Fahed Alosaimi
Nouf Saleh Altalhi
Alaa Rafa Al Saad

المشروع

مرقاب — منصة عمليات أمنية مدعومة بالذكاء الاصطناعي للمنشآت الصغيرة والمتوسطة

27 سبتمبر 2026

كيفية استخدام هذه الوثيقة

توضّح كل إجابة ما يفعله مرقاب **فعليًا** اليوم، وتنتهي بوسم يبيّن الحالة. وإذا كانت الميزة محدودة أو لم يُتحقق منها أو غير منشورة، تذكر الإجابة ذلك صراحة. الأرقام مأخوذة من الشيفرة أو من تشغيل الاختبارات في 27 سبتمبر 2026 (38 مجموعة اختبارات تضم 421 اختبارًا للخادم الخلفي، جميعها ناجحة).

دليل وسوم الحالة

تم التحقق	مُختبَر ومؤكَّد: بمجموعة الاختبارات الآلية (421 اختبارًا ناجحًا في 27 سبتمبر 2026) و/أو باختبار حي موثّق في التقارير الهندسية للفريق.
تم التحقق في المختبر	مؤكَّد من البداية إلى النهاية في مختبر مضبوط داخل حاويات، ولم يُختبر على أجهزة موظفين فعلية.
محدود	مُنفَّذ ويعمل، مع قيد موضّح صراحة.
لم يتم التحقق	مُنفَّذ في الشيفرة لكنه لم يُختبر تشغيليًا.
غير مُنفَّذ	غير متاح في التطبيق.
غير منشور	لا يوجد نشر في بيئة إنتاج.
متوقف (عائق خارجي)	لا يمكن إكماله بسبب اعتماد خارجي.
مخطط	بند مستقبلي في خارطة الطريق، ولم يُبنَ بعد.
عرض / محاكاة	يستخدم بيانات اصطناعية أو بيانات عامة للعرض، لا بيئة حقيقية.

أ. المشكلة والتموضع

1. ما المشكلة التي يحلّها مرقاب؟

تتلقى المنشآت الصغيرة والمتوسطة تنبيهات أمنية خامًا، لكنها تفتقر إلى سير عمل مركز العمليات الأمنية الذي يحوّل هذه التنبيهات إلى قرارات: الفرز، والتحقيق، والاستجابة في الوقت المناسب، وإثبات ما تم. يوفّر مرقاب هذا السير. فهو يحوّل الأحداث إلى حوادث مترابطة قابلة للتفسير مع الأدلة وسياق MITRE، ويمنح كل حادثة عالية أو حرجة مؤقّت استجابة مدته 5 دقائق، ولا ينفّذ الاحتواء إلا بإجراء مُصرَّح به، ومؤكَّد من الوكيل، ومُسجَّل في سجل التدقيق.

2. لماذا المنشآت الصغيرة والمتوسطة؟

لأنها تواجه الهجمات نفسها التي تواجه الشركات الكبرى (التصيّد، وتخمين كلمات المرور، وبرامج الفدية، والقيادة والتحكم)، لكنها نادرًا ما تملك مركز عمليات أمنية بطاقم متفرّغ، أو ميزانية لحلول SIEM/SOAR التجارية، أو قبولًا لإرسال سجلاتها الداخلية إلى أطراف خارجية. لذلك بُني مرقاب على بيانات مفتوحة المصدر (Wazuh وSuricata)، ومنطق حتمي يستطيع فريق صغير فهمه وتدقيقه، مع توجّه نحو ذكاء اصطناعي مستضاف ذاتيًا.

3. لماذا Wazuh؟

لأن Wazuh منصة أمنية مفتوحة المصدر واسعة الانتشار، تضم وكلاء على الأجهزة وآلية مدمجة تُسمّى **الاستجابة النشطة (Active Response)**. وهذا يتيح لمرقاب **استقبال** التنبيهات و**التصرّف** على الجهاز دون ترخيص EDR تجاري. ويملك مرقاب أيضًا واجهة عامة للتحكم بالأجهزة، فيمكن ربط مزوّد EDR أو NAC أو جدار ناري آخر عبر المسار نفسه.

الحالة: نقطة استقبال التنبيهات تم التحقق · العزل عبر الاستجابة النشطة تم التحقق في المختبر · سكربت التحويل من جهة المدير لم يتم التحقق · الإصدار العام 4.14.7 متوقف.

ب. الذكاء الاصطناعي

4. لماذا لا نستخدم ذكاءً اصطناعيًا خارجيًا؟

تحتوي السجلات الأمنية على أسماء أجهزة داخلية، ومستخدمين، وعناوين IP، وأحيانًا بيانات اعتماد، وإرسالها إلى خدمة خارجية يخلق مخاطر على الخصوصية والامتثال ويزيد الاعتماد على طرف ثالث. كما قد تختلق النماذج اللغوية معلومات غير صحيحة، مثل تقنية MITRE غير موجودة. لذلك يعطّل مرقاب الذكاء الاصطناعي الخارجي افتراضيًا. أما تكامل Anthropic Claude الموجود فهو للمقارنة أثناء التطوير فقط، ويتطلب **معًا** مفتاح API **و**تفعيلًا صريحًا للخيار `ALLOW_EXTERNAL_AI_DEV_ONLY=true`.

5. كيف تعمل بنية الذكاء الاصطناعي؟

- **خانة مزوّد واحدة:** لا يعمل أكثر من مزوّد واحد في الوقت نفسه، ولا تُسلسَل المزوّدات. وعند عدم تهيئة أي مزوّد (كما هو الحال اليوم)، تستخدم كل مهمة مؤهلة للذكاء الاصطناعي بديلًا حتميًا قائمًا على القواعد.
- **«وكلاء» مسمّون:** وكيل الحوادث، ووكيل المؤشرات، ووكيل مخاطر MITRE، ووكيل التوصيات، وكلها أغلفة بأقل صلاحيات حول خدمات حتمية محددة. تُسجَّل قراراتها، ولا يستطيع أيٌّ منها إنشاء إجراء استجابة أو الوصول إلى التحكم بالأجهزة.
- **حواجز حماية:** عزل النص لمنع حقن الأوامر، وتحقق صارم من أي مخرجات للذكاء الاصطناعي (مثل مطابقة قيم الخطورة ومعرّفات MITRE مع المرجع)، ومهل زمنية، وقواطع دائرة، وحدّ للطلبات المتزامنة.

الحالة: البنية تم التحقق منها باختبارات الوحدة، ولا يعمل أي نموذج أثناء التشغيل.

6. هل يُستخدم Claude أو OpenAI أو Gemini أثناء التشغيل؟

لا. لا يُستخدم أيٌّ منها أثناء التشغيل ولا في العرض التجريبي. تكامل Claude موجود لكنه معطّل افتراضيًا (بشرطين، وللتطوير فقط). أما OpenAI وGemini فغير مدمجين إطلاقًا. والإشارة الوحيدة إلى «OpenAI» في الشيفرة هي أن المزوّد المستضاف ذاتيًا يستخدم صيغة الطلبات الشائعة «المتوافقة مع OpenAI» التي توفّرها بيئات تشغيل النماذج المحلية.
غير مستخدم أثناء التشغيل

7. كيف تعمل بنية الذكاء الاصطناعي المستضاف ذاتيًا؟

يحدّد المسؤول القيمتين `SELF_HOSTED_AI_URL` و`SELF_HOSTED_AI_MODEL` لخادم نماذج داخل شبكته (مثل llama.cpp أو Ollama أو vLLM أو LocalAI). يرسل مرقاب بيانات مُقلَّصة بصيغة `v1/chat/completions/` المتوافقة مع OpenAI، ويعامل كل رد كنص غير موثوق، ويتحقق منه بصرامة وفق المخطط المتوقع، ويعود إلى القواعد عند أي فشل. يأتي العنوان والنموذج من إعدادات الخادم فقط، ولا يأتيان أبدًا من طلب العميل.

الحالة: لم يتم التحقق غير منشور. لم يُنشر أي نموذج، لأن الحاسوب المحمول المستخدم في التطوير لا يملك العتاد اللازم لتشغيله بأمان إلى جانب المنصة.

ج. التحكم بالوصول

8. كيف يمنع مرقاب الوصول غير المصرّح به؟

- رموز وصول JWT صالحة لـ 15 دقيقة ومثبّتة على خوارزمية HS256، ورموز تحديث صالحة لـ 7 أيام تُدوَّر، وإعادة استخدامها تُلغي سلسلة الرموز كاملة.
- تشفير كلمات المرور بـ bcrypt (12 جولة)، ورسالة خطأ عامة موحّدة عند خطأ البريد أو كلمة المرور، وحدّ 5 طلبات في الدقيقة لتسجيل الدخول والتسجيل واستعادة كلمة المرور.
- تحقق من الأدوار، وتقييد بحسب القسم والمنشأة في كل استعلام، وحراسة على مستوى الكائن للحوادث والتذاكر والأجهزة.
- تحقق صارم من المدخلات (رفض الحقول غير المعروفة)، والتحقق من معرّفات UUID، ورفض البايتات الفارغة. وتوثيق الواجهة معطّل في بيئة الإنتاج.

الحالة: تم التحقق (المراحل الأمنية 1 و5 و11، إضافة إلى اختبارات الوحدة).

9. كيف يعمل التحكم بالوصول القائم على الأدوار (RBAC)؟

الدور	النطاق
`ADMIN` (المدير)	المنشأة كاملة، بما في ذلك إدارة المستخدمين والسياسات والإعدادات.
`SECURITY_ANALYST` (محلل الأمن)	المنشأة كاملة: التحقيق والاستجابة.
`IT_TECHNICIAN` (فني تقنية المعلومات)	حوادث قسمه وأجهزته وتذاكره وأحداثه الفورية فقط.
`EMPLOYEE` (الموظف)	تطبيق الموظف المكتبي فقط، دون الوصول إلى لوحة المركز أو الأحداث الفورية.

أجرت المرحلة الأمنية الأولى 18 اختبارًا حيًّا (مثلًا: فني قسم المالية الذي يطلب أجهزة قسم الهندسة يتلقى رفضًا 403)، ونجحت جميعها. تم التحقق

10. كيف يُطبَّق عزل المنشآت (Tenants)؟

يحمل كل سجل تابع لمنشأة معرّف `organizationId`. تُصفّى الاستعلامات بحسب منشأة المستخدم، والمستخدم الذي لا ينتمي إلى منشأة يحصل على نتيجة فارغة مضمونة (الإغلاق عند الفشل). وترفض حراسات الوصول أي مورد تختلف منشأته عن منشأة المستخدم. وتتبع الإشعارات والتقارير الأسبوعية وغرف الأحداث الفورية القاعدة نفسها.

الحالة: تم التحقق باختبارات الوحدة · محدود: لا يوجد اختبار حي موثّق بعدة منشآت.

د. الاستجابة والاحتواء

11. كيف يعمل عزل الجهاز؟

1. ينقر مستخدم مُصرَّح له بالوصول إلى الحادثة على «عزل الجهاز» ويؤكّد أن هذا الجهاز وحده سيتأثر.
2. يحدّد الخادم الجهاز من الحادثة نفسها، ولا يستطيع جسم الطلب تسمية جهاز.
3. يُحفظ إجراء `ISOLATE_DEVICE` بحالة «قيد الانتظار»، ثم يُستدعى مزوّد التحكم بالأجهزة (الاستجابة النشطة في Wazuh).

4. لا تصبح النتيجة «نجاح» إلا عندما يؤكّد الوكيل نفسه التنفيذ، وإلا تصبح «فشل» مع ذكر السبب. ولا يظهر الجهاز «معزولًا» إلا عند وجود إجراء عزل ناجح فعلًا.

الحالة: تم التحقق في المختبر : عمليتا عزل ناجحتان من أصل 2 على وكيل اختبار آمن (Linux) داخل حاوية، خلال 11–15 ثانية.

12. كيف تعمل الاستجابة النشطة في Wazuh هنا؟

يستدعي مرقاب واجهة Wazuh Manager لتشغيل أمر استجابة نشطة مسجّل على الوكيل المستهدف. يضبط سكربت `isolate-host` على الوكيل الجدار الناري لحجب الحركة، مع استثناء ضيق للاتصال بـ Wazuh ولإرسال التأكيد إلى مرقاب. ثم يرسل نتيجته إلى `devices/endpoint-control/active-response-result/` موثّقة بمفتاح واجهة المراقبة. ولا يعدّ مرقاب ردّ المدير بأن الأمر «أُرسل» نجاحًا بحد ذاته. وقد اكتُشف في المرحلة الأمنية 2A خطآن في السكربت (تعليق عند قراءة المدخل القياسي، وعدم تطابق اسم المضيف) وأُصلحا.

الحالة: سكربت Linux تم التحقق في المختبر · سكربت Windows لم يتم التحقق .

13. ماذا يحدث إذا فشل العزل؟

يُسجَّل الإجراء **فاشلًا** مع السبب (مثل «fetch failed»)، ويظهر الفشل باللون الأحمر في لوحة الحادثة وسجل الاستجابة، ويُرسَل إشعار «نتيجة الاحتواء» للمحاولات التلقائية، ويُقيَّد في سجل التدقيق. ولا يُوسم الجهاز بأنه معزول، ويستطيع المحلل التصعيد أو جمع الأدلة أو إعادة المحاولة. تُظهر لقطات الشاشة في هذه الحزمة حالات فشل حقيقية من بيئة التطوير، لأن الأجهزة الافتراضية لا يوجد خلفها جهاز حقيقي.

14. كيف تُعالَج مسألة عدم التكرار (Idempotency)؟

- **الإقرار:** تكرار «الإقرار» يعيد السجل الموجود دون قيد تدقيق جديد.
- **قرار الاحتواء:** يُتخذ مرة واحدة لكل حادثة داخل معاملة بقفل استشاري في PostgreSQL، مع علامة «انتهاء المهلة» لا تتكرر، فلا يمكن لعدة دورات جدولة أو عدة نسخ من الخادم اتخاذ القرار مرتين.
- **أرقام القضايا:** تُولَّد بعدّاد يومي ذرّي، فلا تتشارك الدفعات المتزامنة الرقم نفسه.
- **الربط:** تنضم الأحداث المرتبطة إلى القضية المفتوحة القائمة بدلًا من إنشاء نسخ مكررة.
- **الإعداد:** لا تُنشئ بيانات البذر واستيراد بيانات العرض إلا العناصر المفقودة، فيُستورد كل حدث من البيانات مرة واحدة على الأكثر.

تم التحقق باختبارات الوحدة.

15. كيف يُدار سجل التدقيق؟

يكتب كل إجراء ذي صلة أمنية قيدًا في سجل التدقيق، ويُستنتج فيه المنفّذ والهدف في الخادم من المستخدم الموثَّق ومن المورد، ولا يُؤخذان أبدًا من جسم الطلب. وتُسجَّل محاولات الوصول المرفوضة وتسجيلات الدخول الفاشلة (والبريد المسجّل فيها هو الهوية التي *حاول* المستخدم الدخول بها). وواجهة سجل التدقيق للقراءة فقط، فلا توجد مسارات للإنشاء أو التعديل أو الحذف. تم التحقق (المرحلة الأمنية 6)

هـ. الاكتشاف والتحقيق

16. كيف تُربط الحوادث؟

يُقارَن الحدث الجديد بالقضايا المفتوحة خلال آخر **72 ساعة** باستخدام محرّك المقارنة نفسه المستخدم في البحث عن الحوادث المشابهة (التقنية والتكتيك، والمؤشرات، والجهاز، والقسم، والتوقيت). إذا بلغت الدرجة **65** يصبح الحدث دليلًا إضافيًا على تلك القضية، وإلا تبدأ قضية جديدة برقم خاص بها. ولا تتلقى القضايا المحلولة أو المغلقة أدلة جديدة. ويوضّح التفصيل بحسب كل بُعد للمحلل سبب دمج الأحداث. تم التحقق

17. كيف تعمل مطابقة MITRE؟

تطابق قواعد حتمية نص الحدث مع مرجع منتقى من **12 تقنية** (T1053، T1068، T1046، T1059، T1204، T1110، T1566، T1486، T1567، T1105، T1071، T1078). والأحداث غير المطابقة تبقى `UNCLASSIFIED` (غير مصنّفة) بدلًا من التخمين. تم التحقق مع تغطية محدودة.

18. كيف تُستخرج مؤشرات الاختراق (IOC)؟

عبر استخراج حتمي بالأنماط من نص الدليل. مؤشرات الاختراق هي عناوين IP، وبصمات الملفات، والنطاقات، والروابط، وعناوين البريد الإلكتروني، ولكلٍّ منها مستوى ثقة. ومؤشرات الهجوم أنماط سلوكية: سرقة بيانات الاعتماد، والانتشار الجانبي، وحقن العمليات، والتنفيذ المُعتَّم، والتهرّب من الدفاعات. وتُستخرج أنماط الاستمرارية والقيادة والتحكم بشكل منفصل. وإذا لم يوجد تطابق فلا يُسجَّل شيء. تم التحقق

19. كيف تعمل ذاكرة الحوادث؟

تُمثَّل الحوادث كمتجهات وتُقارَن بتشابه جيب التمام تنفيذًا ذاتيًا (مكافئ لفهرس FAISS المسطّح للجداء الداخلي دون الاعتماد على مكتبة أصلية). ويقتصر البحث دائمًا على الحوادث التي يحق للمستخدم رؤيتها بحسب القسم والمنشأة. وتعرض لوحة التحقيق أكثر القضايا السابقة تشابهًا، ومتى وقعت، والاستجابات التي نجحت فيها، ومنها تُبنى الحلول المقترحة. تم التحقق

و. سير عمل الاستجابة خلال 5 دقائق

20. كيف يعمل سير عمل الاستجابة خلال 5 دقائق؟

للحوادث العالية والحرجة فقط، يكون الموعد النهائي وقت الاكتشاف + 5 دقائق. يُرسَل إشعار «الاستجابة مطلوبة» لمستخدمي المركز المخوَّلين برؤية الحادثة، وتعرض اللوحة عدًّا تنازليًا حيًا. أما الحوادث المتوسطة والمنخفضة فتنتظر المحلل دائمًا. تم التحقق باختبارات الوحدة، وهو ظاهر في الواجهة.

21. ماذا يحدث عندما يُقرّ الموظف بالحادثة؟

توضيح أولًا: **في مرقاب يتم الإقرار من قِبل فريق المركز** (المدير، أو محلل الأمن، أو فني تقنية المعلومات في القسم نفسه) عبر اللوحة، لا من قِبل الموظف المتأثر، إذ لا يوجد في الخادم الخلفي نموذج لربط الحوادث بموظف. عندما ينقر مستخدم من المركز على «إقرار وبدء التحقيق» أو يغيّر حالة الحادثة، تُسجَّل الاستجابة. فإن كان ذلك قبل الموعد النهائي، يُلغى العزل التلقائي لتلك الحادثة نهائيًا، وإن كان بعده، يُسجَّل كاستجابة متأخرة ولا يُلغي عزلًا بصمت. محدود فيما يخص الموظفين.

22. ماذا يحدث عند انتهاء مهلة الـ 5 دقائق؟

تتخذ عملية خلفية قرارًا واحدًا لكل حادثة تحت قفل في قاعدة البيانات:

- إذا كانت الحادثة **ناتجة عن المحاكاة**، أو كانت سياسة «نافذة الاستجابة 5 دقائق» **معطّلة**، أو **لم يُهيَّأ مزوّد** للتحكم بالأجهزة، يُسجَّل «لم تتم محاولة الاحتواء التلقائي» مع السبب.
- وإلا يُحفظ إجراء `ISOLATE_DEVICE` بحالة «قيد الانتظار» ويُستدعى المزوّد الحقيقي، ثم يتحوّل السجل نفسه إلى «نجاح» أو «فشل» بحسب النتيجة الفعلية.

وفي الحالتين يُكتب إشعار «نتيجة الاحتواء» وقيد تدقيق، ولا يُستشار الذكاء الاصطناعي. محدود : في بيئة التطوير سُجّلت المحاولات التلقائية فاشلة لعدم وجود جهاز يمكن الوصول إليه، ولم يُثبت بعد عزل تلقائي ناجح على وكيل حي.

23. كيف يُمنع وضع المحاكاة من التسبب في عزل حقيقي؟

- تُوسَم أحداث المحاكاة عند استقبالها بالمصدر `SIMULATION` ، وتُستثنى حوادثها **من الاحتواء التلقائي** (مُختبَر بالوحدات).
- يثبّت العرض التجريبي كل إعدادات التحكم بالأجهزة (Wazuh وEDR العام) على قيم فارغة، فلا **يستطيع** عزل أي شيء.
- تظهر الحوادث المحاكاة في الواجهة موسومة بوضوح «محاكاة (اصطناعية)».

قيد: العزل *اليدوي* غير محظور للحوادث المحاكاة، فيستطيع المحلل طلبه بعد نافذة التأكيد للجهاز الذي استهدفته المحاكاة. ويبقى ذلك قرارًا بشريًا صريحًا. تم التحقق للأتمتة · محدود للإجراءات اليدوية.

ز. الحالة

24. ما الذي تم التحقق منه؟

المصادقة والجلسات، والتحكم بالوصول بحسب الأدوار والأقسام (18 من 18 اختبارًا حيًا)، وتقييد المنشآت (باختبارات الوحدة)، والتحقق من المدخلات، وتحديد المعدل، وأمان الأحداث الفورية، وسلامة سجل التدقيق، والاكتشاف، والربط، ومطابقة MITRE، واستخراج المؤشرات، وذاكرة الحوادث، والحلول المقترحة، ومنطق نافذة الاستجابة 5 دقائق، واستثناء المحاكاة، وإشعارات فريق المركز، وتقارير القضايا والتقارير الأسبوعية، ومسارات استقبال Wazuh وSuricata، وعزل الأجهزة **في المختبر**. تنجح 421 اختبارًا للخادم الخلفي، وتجتاز التطبيقات الثلاثة فحص الأنواع دون أخطاء (27 سبتمبر 2026). كما شُغِّل العرض التجريبي كاملًا من البداية إلى النهاية من الشيفرة المضمّنة في الحزمة، ونجحت جميع الفحوصات الـ 48.

25. ما الذي يُعدّ محدودًا؟

نجاح الاحتواء التلقائي على وكيل حي (لم يُعرض بعد)، والعزل خارج المختبر، وتغطية MITRE (12 تقنية)، و«تنبؤات» المخاطر (إحصاءات لا تعلّم آلي)، والإشعارات (لفريق المركز فقط)، وتطبيق الموظف (بيانات تجريبية جزئيًا)، والترجمة العربية (جزئية)، والعرض التجريبي (لم يُشغَّل على جهاز نظيف مستقل).

26. ما الذي لم يُنشر؟

مرقاب ككل، فهو يعمل محليًا عبر Docker دون نطاق عام أو شهادة TLS من جهة موثوقة. ونموذج الذكاء الاصطناعي المستضاف ذاتيًا، إذ لم يُنشر أي نموذج. والذكاء الاصطناعي الخارجي غير مستخدم أثناء التشغيل.

27. ما القيود الحالية؟

1. **غير منشور في بيئة إنتاج:** يعمل محليًا عبر Docker على جهاز التطوير، دون نطاق عام، وبشهادة TLS ذاتية التوقيع.

2. **لا يوجد نموذج ذكاء اصطناعي أثناء التشغيل:** التصنيف ومطابقة MITRE وتقديرات المخاطر والتوصيات كلها حتمية وقائمة على القواعد. المزوّد المستضاف ذاتيًا مُنفَّذ لكن **لم يتم التحقق** منه لعدم نشر أي نموذج. والذكاء الاصطناعي الخارجي (Claude) معطّل افتراضيًا ولا يُستخدم في العرض.
3. **عزل الأجهزة مُتحقَّق منه في المختبر فقط:** عمليتا عزل ناجحتان من أصل 2 على وكيل اختبار آمن (Linux) داخل حاوية. لا اختبارات على أجهزة موظفين فعلية، وسكربت Windows لم يُتحقق منه، ورفع العزل غير مُنفَّذ في التطبيق.
4. **لم يُثبت نجاح الاحتواء التلقائي تشغيليًا:** عند انتهاء المهلة يسجّل مرقاب طلب عزل، وفي بيئة التطوير سُجّلت المحاولات **فاشلة** لعدم وجود جهاز يمكن الوصول إليه.
5. **إصدار Wazuh متوقف:** كانت صورة 4.14.7 العامة لا تزال إصدارًا مرشحًا عند الفحص، واستخدم المختبر ذلك الإصدار.
6. **سكربت التحويل من Wazuh Manager إلى مرقاب لم يُتحقق منه:** تم التحقق من نقطة الاستقبال بحمولات بصيغة Wazuh، لكن السكربت نفسه لم يُشغَّل. ومرقاب **لا** يقرأ من Wazuh Indexer.
7. **تغطية اكتشاف محدودة:** 12 تقنية MITRE منتقاة، والأحداث غير المطابقة تبقى غير مصنّفة.
8. **الإشعارات موجّهة لفريق المركز لا للموظفين أفرادًا**، وتطبيق الموظف المكتبي يستخدم جزئيًا بيانات تجريبية موسومة بوضوح.
9. **ترجمة عربية جزئية** في بعض تسميات لوحة الحادثة.
10. **لا يوجد اختبار أحمال**، ولا اختبار حي بعدة منشآت.
11. **لا توجد أدوات آلية للنسخ الاحتياطي أو التعافي من الكوارث:** النسخ الاحتياطي يدوي (`pg_dump`).
12. **لم يُشغَّل العرض التجريبي على جهاز نظيف:** شُغِّل العرض كاملًا من البداية إلى النهاية من الشيفرة المضمّنة في الحزمة (نجحت 48 من 48 فحصًا)، لكن على جهاز التطوير فقط.
13. **تواريخ المراجعة الأمنية:** اكتملت المراجعة ذات المراحل الـ 18 بين 6 و8 سبتمبر 2026. أما الميزات المضافة بعدها (نافذة الاستجابة المُعاد تصميمها، والحلول المقترحة، والعرض التجريبي) فتغطيها اختبارات الوحدة الحالية، لكنها لم تخضع لمراجعة أمنية مخصصة.

28. ما خارطة الطريق المستقبلية؟

جميع البنود التالية مخطط لها، ولم يُبنَ أيٌّ منها.

1. نشر نموذج مستضاف ذاتيًا وتقييمه على عتاد مناسب.
2. التحقق من العزل على أجهزة Windows وLinux فعلية، وإضافة «رفع العزل».
3. الانتقال إلى إصدار عام من Wazuh وتشغيل التكامل مع المدير من البداية إلى النهاية.
4. النشر في بيئة إنتاج: نطاق حقيقي وTLS، ونسخ احتياطي آلي، وتعافٍ من الكوارث، واختبار أحمال.
5. توسيع تغطية الاكتشاف، واستكمال الترجمة العربية، وإشعارات على مستوى الموظف.
6. مراجعة أمنية مخصصة للميزات المضافة بعد 8 سبتمبر 2026.